

Статья Захват домена Active Directory: от учётки стажёра до Domain Admin мимо SOC за миллионы

 codeby.net/threads/zakhvat-domena-active-directory-ot-uchetki-stazhera-do-domain-admin-mimo-soc-za-milliony.92782

April 22, 2026

[Добавить закладку](#)



За последний год я провёл десятки внутренних пентестов в организациях с сертифицированными SOC, enterprise-уровня SIEM и EDR на каждом эндпоинте. Время от получения учётки рядового сотрудника до прав Domain Admin в среднем не превышало 30 минут. Не потому что я гений - а потому что захват домена Active Directory эксплуатирует не дыры в софте, а дыры в процессах. Каждый раз одно и то же: дорогой зоопарк средств защиты, а под ним - болото из дефолтных настроек и паролей, которые не менялись со времён Windows Server 2008.

Текст записан со слов моего коллеги. Повествование от первого лица.
Приятного чтения.

По данным Verizon DBIR 2025 (на которые ссылается исследование Qualys), 74% успешных взломов связаны с компрометацией учётных данных. Не zero-day. Не сложный exploit. Kerberoasting сервисной учётки с паролем, который не менялся три года. Нетронутый пароль krbtgt. Domain Admin, который логинится на рабочую станцию бухгалтерии «помочь с принтером». Организация тратит десятки миллионов на средства защиты - и остаётся беззащитной, потому что зрелость процессов ИБ не

дотягивает до уровня угроз - я подробно разбирал эту проблему в [обзоре зрелости программы кибербезопасности](#).

Эта статья - не пересказ документации Microsoft и не перечисление атак по списку. Это разбор реальной цепочки domain takeover глазами пентестера: что конкретно делает атакующий, почему дорогие средства защиты этого не видят, и какие шаги закрывают путь к компрометации домена без дополнительного бюджета.

Первые 15 минут атакующего в Active Directory

Требования к окружению для воспроизведения: одна доменная учётка уровня Domain Users (например, полученная через фишинг учётка стажёра), доступ к внутренней сети, набор инструментов - Impacket, Rubeus, BloodHound/SharpHound. Всё описанное работает на стандартных Windows Server 2016/2019/2022 с дефолтными настройками аудита.

По данным Horizon3.ai, собранным на сотнях production-доменов, рабочий процесс атакующего после получения начального доступа выглядит однообразно - и именно эта предсказуемость делает его настолько эффективным. Одни и те же шаги, одни и те же ошибки на стороне защиты.

0–3 минуты: разведка. Атакующий шлёт LDAP-запросы к контроллеру домена - перечисляет пользователей, группы, описания учёток и Service Principal Names. SharpHound строит граф атак, PowerView или голые LDAP-запросы дополняют картину. Техника Domain Groups (T1069.002, Discovery) мгновенно показывает состав привилегированных групп. На этом же этапе вылезают пароли в полях Description - по данным Horizon3.ai, они встречаются примерно в каждом пятом домене. Тут же находятся сервисные аккаунты с SPN и пользователи с отключённой Kerberos pre-authentication.

3–7 минут: сбор Kerberos-тикетов. Найденные SPN-аккаунты атакуются через Kerberoasting ([T1558.003, Credential Access](#)) - запрашиваются сервисные TGS-тикеты, зашифрованные хэшем пароля сервисной учётки. Тикеты уходят на офлайн-перебор. Параллельно собираются AS-REP-ответы для пользователей с отключённой pre-authentication.

7–12 минут: офлайн-взлом. Пока хэши крутятся в hashcat, атакующий анализирует граф BloodHound - ищет кратчайший путь до Tier-0: контроллеры домена, учётки

Enterprise Admins. Слабые пароли сервисных учёток вскрываются за минуты или секунды - зависит от длины и сложности (а сложности там обычно немного).

12–15 минут: lateral movement. Взломанные учётные данные используются для доступа к серверам. Если хоть на одном хосте в памяти LSASS лежит сессия администратора домена - финал предreshён. Pass-the-Hash (T1550.002), затем DCSync (T1003.006) - и атакующий владеет хэшами всех учёток домена.

Ни один шаг не требует малвари. Ни один не генерирует алерт в EDR по умолчанию. Всё - нативный Windows-трафик по стандартным протоколам Kerberos и NTLM. Для SOC это выглядит как обычный рабочий день.

[Атаки на Active Directory: цепочка техник для domain takeover](#)

Типичная цепочка атак на Active Directory при захвате домена линейна до скуки: Initial Access → Credential Dumping → Pass-the-Hash или Pass-the-Ticket → Lateral Movement → Privilege Escalation → полная компрометация домена. На каждом этапе - конкретные техники с конкретными MITRE ATT&CK-идентификаторами и конкретные слепые зоны в защите.

[Kerberoasting и AS-REP Roasting - тихий сбор учётных данных](#)

Kerberoasting (T1558.003, Credential Access) - самая массовая атака на Active Directory. Механика простая: любой доменный пользователь вправе запросить TGS-тикет для любого SPN в домене. Тикет шифруется хэшем пароля сервисной учётки. Атакующий забирает тикет и ломает его офлайн на своём железе - контроллер домена об этом ничего не знает.

По данным Horizon3.ai, SPN-аккаунты с уязвимыми для Kerberoasting паролями присутствуют в подавляющем большинстве production-доменов. Причина банальна: сервисные учётки создаются для SQL Server, IIS, SharePoint, назначается «временный» пароль - и никто его не меняет годами. Я на одном проекте нашёл сервисную учётку MSSQL с паролем Qwerty123!, которая не менялась с 2019 года. И это был банк.

Через Impacket атака запускается одной командой: GetUserSPNs.py -request -dc-ip <DC_IP> <DOMAIN>/<user>:<pass>, через Rubeus - Rubeus.exe kerberoast /outfile:hashes.txt. Оба варианта порождают стандартные TGS-запросы, неотличимые от легитимных на уровне сетевого трафика.

AS-REP Roasting работает аналогично, но бьёт по пользователям с отключённой Kerberos pre-authentication. Для них даже пароль не нужен - достаточно знать имя учётки. Через Impacket: `GetNPUsers.py <DOMAIN>/ -dc-ip <DC_IP> -usersfile users.txt -format hashcat`. Такие аккаунты, по данным Horizon3.ai, встречаются реже - но в legacy-доменах после миграций они типичны.

Ключевая проблема для защиты: взлом хэша происходит офлайн, на GPU атакующего. Единственное место перехвата - момент запроса тикета: Event ID 4769 (A Kerberos service ticket was requested) на контроллере домена. Но без фильтрации по аномальному количеству запросов от одного пользователя этот евент тонет в миллионах легитимных. Противодействие: gMSA ([Group Managed Service Accounts](#)) с автоматической ротацией пароля каждые 30 дней и генерацией случайных паролей до 240 символов - подбор такого хэша нереален.

Pass-the-Hash и Pass-the-Ticket - lateral movement Active Directory

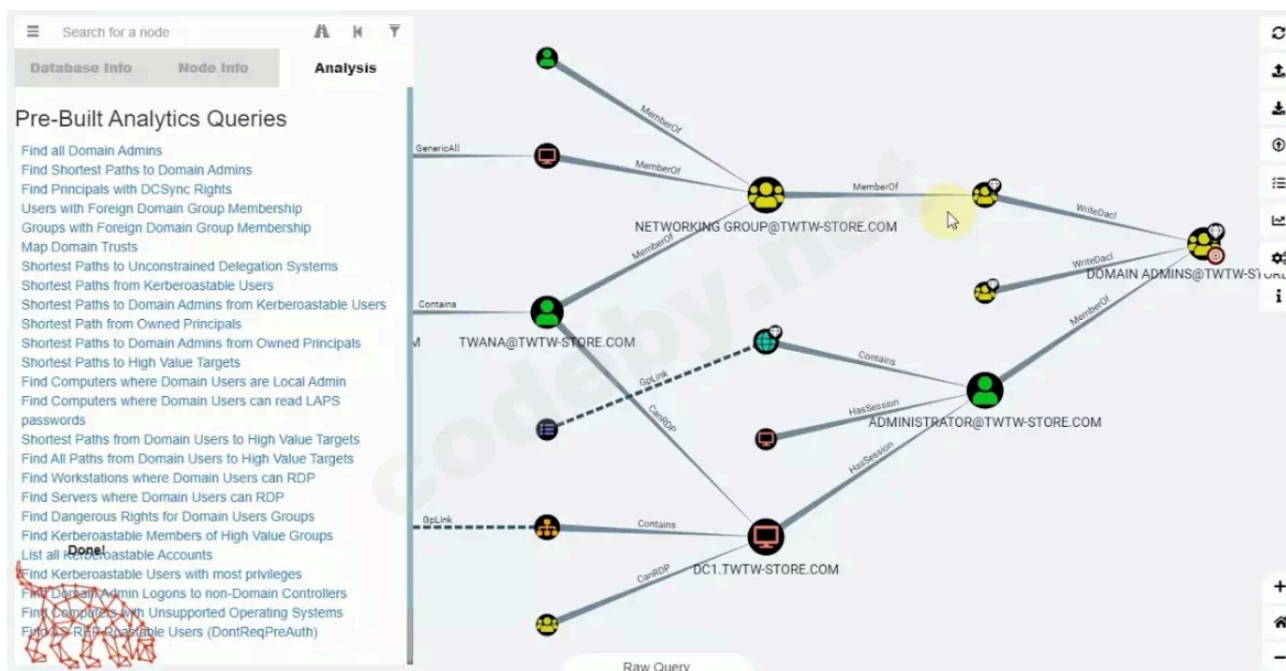
Pass-the-Hash ([T1550.002, Defense Evasion](#) / Lateral Movement) - техника, при которой атакующий аутентифицируется по NTLM, предъявляя хэш пароля вместо самого пароля. Windows принимает хэш напрямую - это не баг, а архитектурная особенность протокола NTLM. Мелкософт так задумали, и вот уже 20+ лет мы с этим живём.

Как отмечают исследователи Qualys, для успешного Pass-the-Hash нужно, чтобы привилегированный пользователь хотя бы раз залогинился на скомпрометированный хост: тогда его NTLM-хэш остаётся в памяти процесса LSASS. На практике это происходит постоянно. Админ подключается к рабочей станции через RDP - «быстренько починить принтер» - его хэш оседает в памяти. Через месяц атакующий его оттуда вытаскивает. Классический `sekurlsa::logonpasswords` в Mimikatz достаёт все хэши из LSASS, дальше `sekurlsa::pth` для Pass-the-Hash. CrackMapExec автоматизирует проверку хэшей по подсети: `crackmapexec smb <subnet> -u admin -H <hash>` - и за пару минут видно, куда этот хэш пускает.

Pass-the-Ticket (T1550.003, Defense Evasion / Lateral Movement) - аналогичная техника, но с украденным Kerberos-тикетом (TGT или TGS) вместо NTLM-хэша. Тикет живёт до истечения срока (по умолчанию 10 часов для TGT), и отследить его использование сложнее, чем NTLM-аутентификацию - Kerberos всё-таки предпочтительный протокол в доменной среде, и его трафик никого не удивляет.

Обе техники - основа [lateral movement Active Directory](#), перемещения между хостами внутри домена. Если на одном из хостов обнаруживается сессия привилегированного

пользователя - атакующий мгновенно повышает права. BloodHound визуализирует эти связи как граф: какие сессии на каких машинах, и какой путь ведёт к Domain Admin за минимальное число шагов. На практике два-три прыжка - и ты у цели.



DCSync и Golden Ticket - полный захват домена Active Directory

DCSync ([T1003.006](#), [Credential Access](#)) - имитация контроллера домена через протокол репликации Directory Replication Service. Атакующий с правами Replicating Directory Changes и Replicating Directory Changes All запрашивает у DC хэши паролей любых пользователей - включая krbtgt и всех администраторов.

Для DCSync не нужен физический доступ к контроллеру домена. Достаточно скомпрометировать учётку с правами репликации - а это часто сервисные аккаунты средств мониторинга или backup-решений. На реальных проектах я неоднократно находил сервисные учётки SCCM или Veeam с правами репликации, пароль которых не менялся с момента настройки. Однажды это был пароль Backup2020! на дворе 2025 года.

Через Impacket: `secretsdump.py <DOMAIN>/<user>:<pass>@<DC_IP>`. Через Mimikatz: `lsadump::dcsync /domain:<DOMAIN> /user:krbtgt`. Результат - полный дамп хэшей из NTDS.dit без остановки службы и без обращения к файловой системе контроллера. Тихо, чисто, незаметно.

Golden Ticket (T1558.001, Credential Access) - подделка TGT Kerberos с использованием хэша krbtgt. С Golden Ticket атакующий создаёт тикет для любого пользователя домена с произвольными привилегиями. Тикет валиден до двойной смены пароля krbtgt - не одинарной, а именно двойной, с интервалом, превышающим максимальное время жизни тикета. Многие об этом не знают и после инцидента меняют krbtgt один раз - а потом удивляются, почему атакующий всё ещё внутри.

На практике пароль krbtgt в абсолютном большинстве доменов не менялся с момента создания. Это означает: после однократного DCSync атакующий получает постоянный доступ к домену на неопределённый срок, даже если все пользовательские пароли будут сброшены. Золотой билет - он потому и золотой.

Отдельная угроза - DCShadow (T1207, Rogue Domain Controller, Defense Evasion): регистрация поддельного контроллера домена для скрытного внесения изменений в каталог. В отличие от DCSync, который читает данные, DCShadow позволяет записывать - модифицировать объекты AD, добавлять бэкдоры в ACL, менять групповые политики (T1484.001, Group Policy Modification, Defense Evasion / Privilege Escalation). Обнаружить DCShadow при стандартном аудите - задача нетривиальная, мягко говоря.

Почему большие бюджеты не защищают от захвата домена

Я регулярно вижу организации с годовым бюджетом на ИБ в десятки миллионов рублей, где domain takeover занимает менее получаса. Причина не в плохих продуктах - а в трёх системных проблемах, которые бюджетом не закрываются.

SIEM без корреляции - дорогой лог-коллектор

Большинство внедрений SIEM ограничиваются сбором логов с дефолтной политикой аудита Windows. А дефолтная политика не записывает то, что нужно.

Чтобы обнаружить DCSync, нужны события 4662 (An operation was performed on an object) с фильтрацией по правам Replicating Directory Changes - это подкатегория Audit Directory Service Access. Для Kerberoasting - события 4769 с анализом аномального числа запросов от одного источника, подкатегория Audit Kerberos Service Ticket Operations. Для DCShadow - события 4932 (Synchronization of a replica of an Active Directory naming context has begun) и 4937, подкатегория Audit Directory Service Replication.

Ничего из этого не включено по умолчанию. Нужна Advanced Audit Policy с конкретными subcategories. Без этих настроек SIEM за любые деньги - просто дорогой лог-коллектор. Красивые дашборды, ноль полезных алертов. Проверьте прямо сейчас: откройте свой SIEM и поищите события 4662 с фильтром по 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2 (GUID права Replicating Directory Changes All). Если их нет - DCSync пройдёт мимо вашего SOC, сколько бы аналитиков там ни сидело. Какие именно события должны попасть в корреляцию:



Вопрос к читателям

Коллеги, в статье упомянут GUID 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2 для детекта DCSync через Event ID 4662 - но на практике одного этого фильтра недостаточно: легитимная репликация между DC генерирует те же события. Как вы разделяете шум от реальных DC-реплик и аномальный DCSync с рабочей станции? Покажите вашу KQL- или SPL-корреляцию: какие поля комбинируете - SubjectUserName, IPAddress, ObjectType, Properties? Используете ли второй GUID 1131f6aa-9c07-11d1-f79f-00c04fc2dcd2 (Replicating Directory Changes) в связке с первым, или достаточно одного? И включена ли у вас подкатегория Audit Directory Service Access через `auditpol /set /subcategory:"Directory Service Access" /success:enable` - или настраиваете через GPO?

Последнее редактирование модератором: